

B\G

RAPPORT #1

In-House AI Security

Préparé par Mohamed Amin Ayed

INTRODUCTION

Ce rapport a pour but de résumer mes recherches des concepts techniques concernant le projet tutoré intitulé **In-House AI Security (AI Gateway, Access Control, AI Guardrails & DLP)** et répondre principalement aux questions suivantes :

- C'est quoi un LLM ?
- C'est quoi un AI Client et son interaction avec un LLM et des outils externes ?
- C'est quoi MCP et le rôle des MCP Servers ?
- Quelle est la relation entre un LLM, un AI Client et des MCP Servers ?
- Identifier les principaux scénarios de menace liés aux LLM, aux AI Clients et aux MCP Servers.
- C'est quoi une AI Gateway ? quel est son role dans la sécurisation des flux IA ?
- C'est quoi DLP? comment peut-on utiliser DLP dans le contexte IA ?
- c'est quoi AI Guardrails ? quel est son role dans la sécurisation des flux IA ?

1. LLMs

Pour pouvoir comprendre ces sont quoi les **Large Language Models (LLMs)**, on doit tout d'abord avoir une vue d'ensemble sur l'IA pour placer les LLMs dans leurs contextes ;

En effet, l'IA est la technologie qui emploie des systèmes intelligents pour résoudre des problèmes sans des règles spécifiques au préalable mais en distinguant des motifs dans.

Cette technologie inclue plusieurs approches, l'une la plus révolutionnaire, c'est le Machine Learning (ML) ; où on utilise des équations mathématiques afin de créer des modèles de prédiction ou de classification selon les 'features' qu'on décide afin de résoudre notre problématique cible.

Cette approche inclue elle-même plusieurs méthodes ; tel que le 'supervised', 'unsupervised' or 'self-supervised learning'.

Le ML inclue aussi une approche appelée Deep Learning (DL) qui se démarque dans l'apprentissage non supervisé*, et qui a vécu une popularité grâce au Boom de data dans le monde, des milliers de Téraoctets de données circulant le monde servent comme l'étincelle pour qu'on exploite la vraie puissance des algorithmes de DL.

Cette arborescence ne se termine pas ici, car le DL dépend des algorithmes tel que les réseaux de neurones pour extraire des 'features' automatiquement.

Et grâce au papier qu'a publié Google en 2017 ; **"Attention Is All You Need"** introduisant l'architecture des **Transformers***, on a vécu la vraie naissance des **Large Language Models LLMs**.

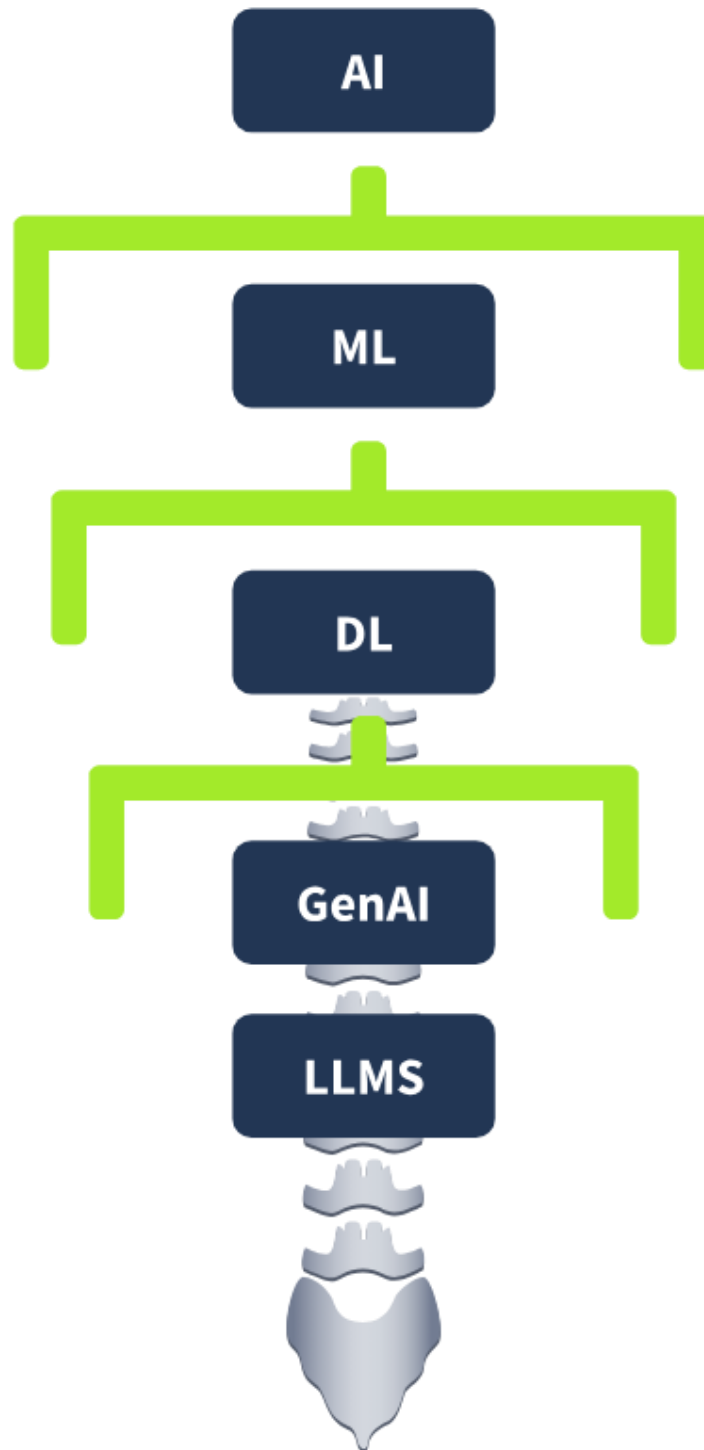
LLMs s'inscrivent sous le GenAI spécialisé à la génération des textes (langage humain, code...)

Ces Derniers, et après exécuter la phase de 'Tokenisation*', excellent à comprendre les textes en donnant des poids d'importances aux mots selon leur significativité dans la phrase entière, afin de mieux comprendre le contexte.

les LLMs essayent ensuite de prédire le 'Token/mot' suivante la plus probable qui servira dans le contexte actuel,

Ces modèles, tel que GPT4, Gemini, ne font ça qu'après être entraînée sur des milliers de Téraoctets de texte en parallèle, afin de comprendre la langue, grammaire etc...

*à détailler



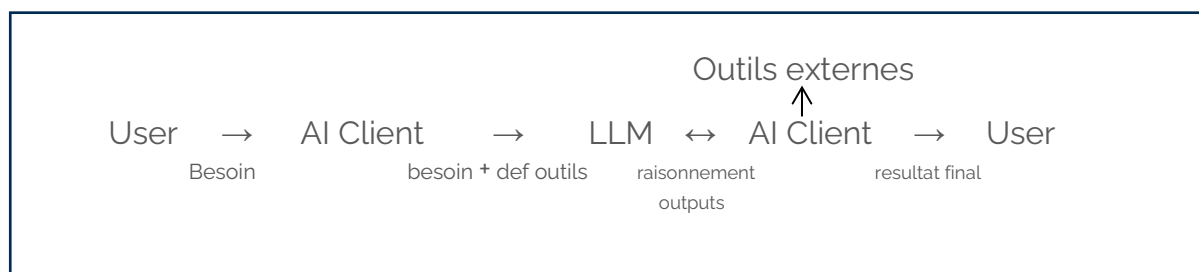
[Tryhackme -- AI RedTeaming path]

2. AI Client et son interaction avec un LLM et des outils externes ?

Un AI client est un logiciel qui, comme son nom l'implique, interagit avec des modèles IA, plus précisément des LLMs et les connectent avec des outils variés afin d'exécuter les tâches de l'utilisateur.

Réellement l'accès des LLM aux outils n'est pas directe, en fait l'AI client gère cette communication en précisant aux LLMs les outils disponibles et comment les utiliser, ce dernier raisonne et communique ses décisions au client, qui invoquera donc les outils demandés^{*}.

Un exemple pertinent peut être un 'coding assistant, chat app' :



Une distinction importante, en termes de sécurité, c'est que le LLM peut demander l'exécution d'une opération avec un outil, ne signifie pas que le client peut l'exécuter.

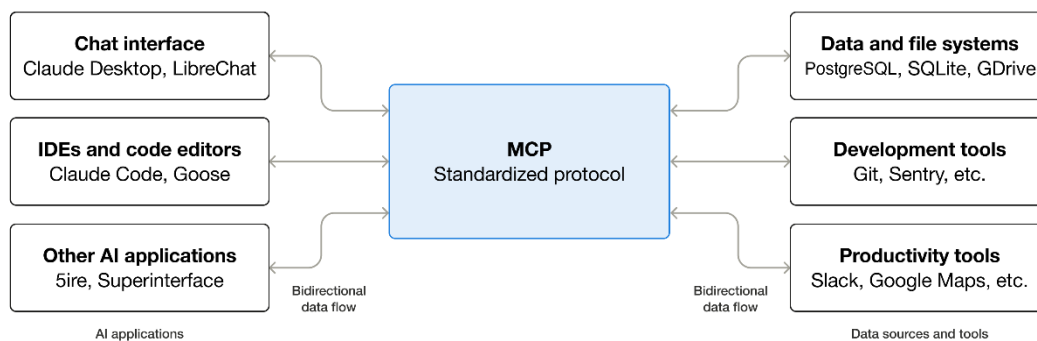
Donc des politiques d'accès, prenant en considération, l'utilisateur, le client et les LLMs, doivent impérativement être mises en place pour sécuriser ces interactions, avec une approche defense-in-depth avec une granularité importante (allowed tools for LLM access per user, access to paths, actions per tool etc...)

^{*}à détailler

3. C'est quoi MCP et le rôle des MCP Servers ?

"MCP (Model Context Protocol) is an open-source standard for connecting AI applications to external systems." *[modelcontextprotocol.io]*

C'est un protocole qui permet aux applications basées sur l'IA (AI Clients) d'accéder facilement et d'une manière standardisée à des outils et sources de données sans être obligé de programmer des règles spécifiques pour chaque outil ou source de données.



[Intégration de l'MCP dans le workflow]

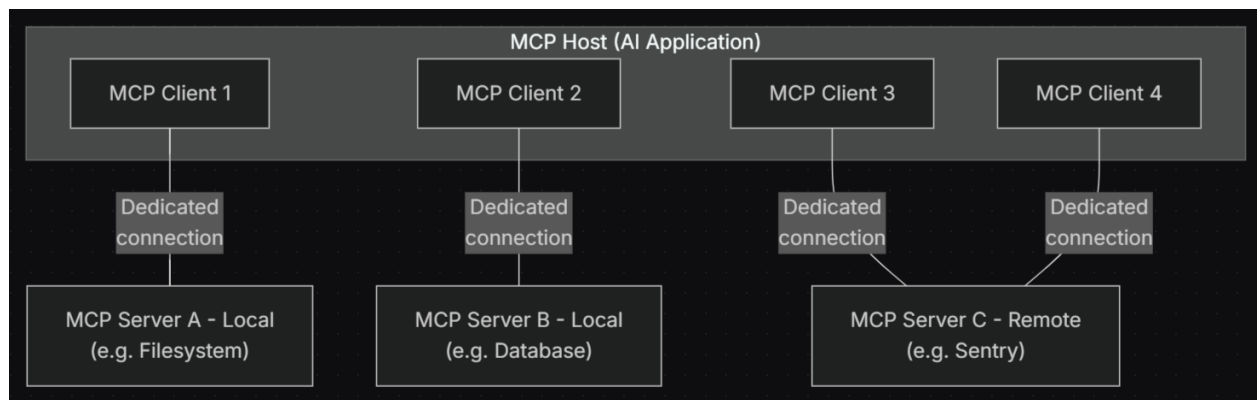
Pour mieux comprendre la puissance de l'MCP, On doit comparer le même cas d'usage sans MCP et avec MCP :

En effet, Si notre AI Client devrait connecter a plusieurs outils variés pour réaliser des missions différentes, sans MCP, les développeurs devront configurer leur application a communiquer avec chaque outil en respectant les exigences de chacun (protocole de communication, format de données...). Ce qui n'est pas scalable de tout

Alors que dans le cas où le MCP est utilisé, le AI client se communique avec le MCP server associe à l'outil en respectant le protocole, et ce dernier s'occupe des spécificités de la communication avec l'outil il même.

Tout Ça se fait grâce à une architecture, qui est constituée principalement de :

- **Hôte MCP** : le AI Client qui s'occupe de la coordination d'un ou plusieurs Clients MCP.
- **Client MCP** : le composant que déploie l'hôte MCP pour établir et maintenir la connexion avec le Server MCP et obtenir contexte* du serveur MCP demandée par l'hôte MCP.
- **Serveur MCP** : le composant qui offre le contexte de l'outil envisagé.



[Architecture MCP]

Ce que fait tourner MCP, ce sont les deux couches* :

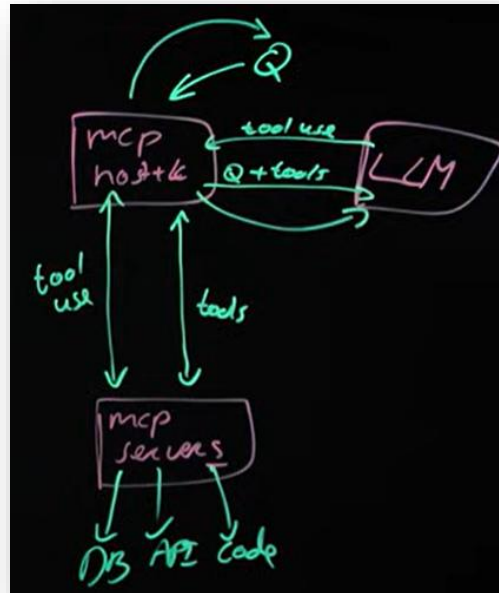
- **DATA** : decouverte, outils, prompt templates etc...
- **Transport** : auth, mecanismes de communications :
 - **STDIO**
 - **http**

Ces MCP servers sont cruciaux dans des environnement IA, donc leur sécurité est indispensable, quelques approches peuvent inclure **Token Isolation**, **Garde-fous imbriqués**, **control d'accès strict**. etc...

*à détailler

4. Quelle est la relation entre LLM, AI Client et MCP Servers ?

Il est clair maintenant que les LLM, AI Client et MCP servers sont vitaux pour booster les environnements IA, mais comment fonctionnent-ils ensemble ?



[Sketch du flow résumant la relation entre LLM, AI client et MCP server]

Ce Sketch peut aider à visualiser les relations et interactions de ces composants l'un avec l'autre :

On commence par l'utilisateur qui envoie sa demande ou question (Q) vers l'hôte MCP, qui va consulter le MCP server pour obtenir un résumé sur les outils et fonctionnalités disponibles, et il transfère cette réponse vers l'LLM avec la question de l'utilisateur. L'LLM raisonne et décide sur quels outils utiliser et avec quels paramètres, qui sont envoyée vers l'hôte et puis vers le MCP server qui garantit les exécutions des outils et livre la réponse à l'hôte. Ce dernier passe ces outputs par l'LLM qui l'analyse et en déduit une réponse, que l'hôte reçoit et livre finalement à l'utilisateur.

⇒ **Bref, LLM raisonne, AI Client orchestre, et le MCP Server expose des fonctionnalités.**

5. C'est quoi une AI Gateway et son rôle dans la sécurisation des flux IA ?

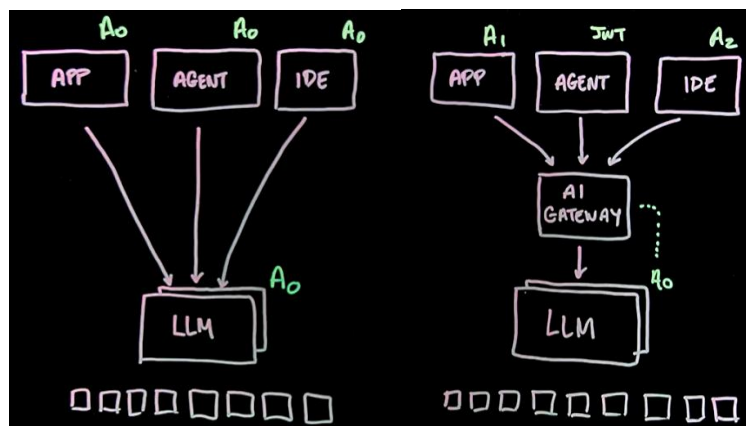
"An AI gateway is a specialized middleware platform that facilitates the integration, deployment and management of AI tools." [IBM]

Une AI gateway gère, sécurise et optimise les interactions avec des application d'IA (LLM, outils IA etc...)

Elle est responsable dans le routage des requêtes destinées aux applications d'IA*.

Aussi l'un de ces rôles c'est la sécurité, et elle le fait grâce à des mécanismes* comme :

- Gestion des clés



- Rate limiting
- Usage reporting
- Guard-fou
 - Intercepter et masquer ou bloquer les prompt et réponses (DLP, attaques...)
 - plus rapide de bloquer d'attaques nouvellement découvertes que mettre a jour les applications clients ou l'application IA cible.

Exemples:

PortKey Gateway, Bifrost, LiteLLM, Kong AI Gateway, cloudflare AI gateway etc...

6. C'est quoi DLP? comment peut-on utiliser DLP dans le contexte IA ?

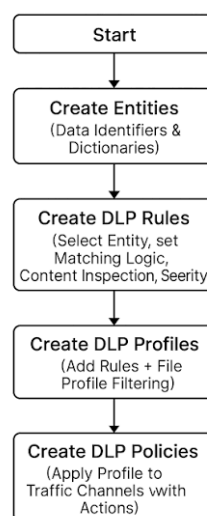
la Data Loss Prevention ou DLP, est un ensemble de strategies ou techniques de cybersecurite qui ont comme but la prevention contre la perte ou l'accès non autorisee aux données.

DLP se repose sur :

- **l'identification** ; mettre en place les règles qui définissent les données sensibles,
- **la surveillance** ; la surveillance constante des flux de données et détection selon les règles
- **Blocage**

Dans le contexte de l'IA, et dans le cadre de notre projet « **IN-House** AI security », le DLP peut servir contre l'exfiltration interne et externe des données, et accès non autorisés par une supervision constante, qui doit veiller à détecter les flux de données suspects ; dans les réseaux et les hôtes, soit entre les clients et les LLMs, ou entre les LLMs et les outils etc...

Une solution qui s'excelle dans la défense des environnements IA contre la fuite de données c'est Netskope, avec **Netskope One DLP** s'occupe des opérations de DLP pareils soit via des VMs déployées on-premises ou hébergées sur le cloud et routé via Netskope Private Access (NPA), avec des configurations personnalisables :



[Netskope DLP Policy creation flow]

7. c'est quoi AI Guardrails ? quel est son rôle dans la sécurisation des flux IA ?

Les AI Guardrails sont des mécanismes pour sécuriser les flux entrant et sortants aux applications IA.

Puisque ces application dépendent des inputs/outputs non-déterministes, donc la surveillance doit s'adapter, et c'est pour cela, les AI Guardrails suivent des approches de surveillances et analyses sémantiques, basées sur des mini-llm pour détecter des attaques (tel que les prompts injections data poisoning...) dans les requêtes et réponses AI*.

Netskope offre aussi une solution de garde-fou ; 'Netskope One AI Guardrails' qui utilise le "Inline Inspection" pour analyser en temps réel les prompts et les réponses pour repérer et bloquer les attaques comme Le Jailbreaking, Le Prompt Injection, ghost commands* etc...

8. Conclusion

Nous avons, a ce stage-là, découvert l'architecture et l'interconnexion des écosystèmes IA (LLM, AI Client, protocoles MCP...) tout en identifiant leurs risques et la nécessité d'une stratégie de défense en profondeur grâce a des garde-fous, DLP, AI gateway... pour sécuriser efficacement les flux d'IA.

*à détailler

<https://arxiv.org/pdf/2509.14956>

<https://mohamedaminayedportfolio.netlify.app>

2026-2027